

Zero Trust для ИИ-агентов

Комплект внедрения и приёмки промышленного пилота · версия 5.0

Состав: финальный чек-лист, стоп-критерии, метрики успеха, Runbook оператора, waiver-процесс, OPA/Rego reference policy, тест-кейсы и шаблон журнала инцидента.

Часть I. Финальный чек-лист пилота

1. Инвентаризация и критичность

№	Требование	Проверяемый результат	Статус
1	Инвентаризировать агентов, владельцев, runtime, MCP/API tools, данные, внешние направления и дерево делегирования.	Реестр покрывает 100% пилотного контура; неучтённых агентов и инструментов нет.	☐
2	Классифицировать по четырём осям: чувствительность данных, изменяющие права, автономность, длительность задачи/сессии.	Для каждого агента заданы класс, max task duration, grace period, TTL и owner.	☐
3	Определить необратимые действия и внешние эффекты.	Для каждого действия задан human approval, технический запрет или waiver с компенсирующими контролями.	☐

2. Identity, attestation и authorization enforcement

№	Требование	Проверяемый результат	Статус
4	Выдать отдельную workload identity каждому логическому агенту; исключить неатрибутируемые shared credentials.	agent_id, instance_id, initiating_user и root_agent_id различимы end-to-end.	☐
5	Для high/critical проводить runtime attestation до выдачи credentials.	Провал attestation зафиксирован в логах, credentials не выпущены, агент остановлен.	☐
6	Использовать scoped short-lived credentials; revoke аннулирует access и refresh credentials; reissue только после повторной attestation.	Старая сессия невозможна; новая выдача не расширяет исходные полномочия.	☐
7	Разместить PDP вне процесса агента; PER - в API/MCP gateway, sidecar, service mesh или целевом сервисе.	Агент не может разрешить себе tool call или обойти enforcement point.	☐
8	Привязать кеш решения к версии policy. При смене версии старые решения инвалидируются атомарно; in-flight запросы обрабатываются по заранее определённому правилу.	Нет использования устаревшего allow после изменения критичной policy; результат проверен тестом смены версии.	☐

3. Data controls, RAG и blast radius

№	Требование	Проверяемый результат	Статус
9	Default deny для tools, операций, network destinations и data classes.	Запрещённый вызов блокируется до выполнения.	☐
10	Ограничить объём и частоту на request, task и всё дерево агентов. Счётчики вести в trusted atomic state store.	Субагенты и параллельные запросы не обходят task/tree budget.	☐
11	Для RAG ограничить top-k, chunks, context size и	Серия синонимичных retrieval-запросов не	☐

№	Требование	Проверяемый результат	Статус
	суммарный semantic budget за задачу и дерево.	превышает общий бюджет.	
12	Применять обязательные metadata filters tenant/project/owner/data_class на retrieval layer.	Чужие документы не возвращаются ни прямым, ни семантическим запросом.	☐
13	Маскирование применять на уровне данных одинаково для API, JOIN, alternate endpoints и MCP tools.	Один атрибут нельзя получить без маскировки альтернативным путём; агент не получает отдельный сигнал о применённой маске.	☐
14	Контролировать export по доменам, регионам, форматам, времени и behavioural baseline.	Превышение объёма или географическое несоответствие блокируется либо создаёт priority alert по классу критичности.	☐

4. Attribution, telemetry и policy audit

№	Требование	Проверяемый результат	Статус
15	Передавать initiating_user, agent_id, parent_agent, root_agent, task_id, session_id, policy_version, trace_id.	Полная цепочка восстанавливается из независимых источников.	☐
16	Для каждого внешнего сервиса выполнить end-to-end интеграционный тест приёма и сохранения контекста.	Результат теста документирован по каждому сервису; failure на критическом пути блокирует запуск.	☐
17	Сопоставлять IAM/PDP/PEP, runtime, MCP/API gateway, Syslog/NetFlow и traces.	Инцидент реконструируется без доверия к одному источнику.	☐
18	Аудировать изменения policy; critical changes - four-eyes approval.	100% изменений имеют автора, время, причину, версию и согласование.	☐

5. Incident response, revoke и rollback

№	Требование	Проверяемый результат	Статус
19	Провести indirect prompt injection с запрещённым tool call и export attempt.	PEP блокирует; owner/SOC уведомлены; новые сессии остановлены.	☐
20	Проверить revoke → reissue.	Access/refresh credentials старой сессии недействительны; новая выдача требует attestation и актуальную policy.	☐
21	Для изменяющих операций определить rollback/compensating transaction и RTO до пилота.	Откат выполнен в заданный RTO (< X минут, значение утверждается до старта).	☐
22	Необратимые действия требуют human approval с TTL, single-use и запретом autoretry.	Просроченное approval не исполняется; новое действие требует нового одобрения.	☐

Стоп-критерии: пилот не допускается к запуску

- High/critical агент не поддерживает attestation или при её провале получает credentials.
- PDP находится внутри агента либо PEP можно обойти.
- Policy cache не связан с policy version или не инвалидируется атомарно.
- Trusted state store не атомарный, доступен агенту на запись или не учитывает task/tree budgets.
- Лимиты request/task/tree не суммируются на всё дерево агентов.
- RAG работает без metadata filters или допускает обход cumulative semantic budget.
- Защищаемый атрибут доступен через альтернативный endpoint/JOIN без эквивалентного контроля.
- Критический сервис не принимает и не сохраняет обязательный attribution context.
- Revoke не аннулирует refresh credentials или reissue не требует attestation.
- Необратимое действие выполняется без действующего human approval.
- Critical policy changes не аудированы или не требуют второго согласования.
- Критичное исключение действует без CISO/архитектор approval, срока и compensating controls.

Критерии успешного завершения пилота

Метрика	Целевое значение
Policy enforcement	100% запрещённых тестовых tool calls заблокированы до выполнения.
Detection & containment	Критичный сценарий обнаружен и технически остановлен < 60 секунд.
Attribution coverage	100% сервисов critical path сохраняют обязательный контекст.
Revocation	100% старых access/refresh credentials недействительны после revoke.
Data/RAG controls	0 обходов metadata scope, task budget и tree budget.
Rollback RTO	Изменяющие операции откатываются менее чем за X минут; X утверждается до пилота.
False positives	Не выше утверждённого порога; порог и методика заданы до старта.
Policy audit	100% critical changes имеют автора, причину, policy version и second approval.

Часть II. Runbook оператора

Цель: остановить агентный инцидент, подтвердить revoke и сохранить доказательства. Команды ниже адаптируются под конкретные IAM/PDP/PEP/SIEM.

Шаг	Действие оператора	Подтверждение
1. Triage	Найти agent_id, session_id, task_id, root_agent_id, trace_id, policy_version; определить criticality и owner.	Incident ID создан; контекст приложен.
2. Contain	На PEP заблокировать agent/session; запретить новые сессии; при необходимости изолировать VLAN/namespace/egress identity.	Новый deny виден в PDP/PEP и Syslog.
3. Revoke	Отозвать access + refresh credentials; прекратить выдачу новых credentials.	Повторный запрос старым credential получает deny.
4. Attest	Повторно проверить image/runtime measurement. При failure оставить агент заблокированным.	Attestation result записан.
5. Validate policy	Проверить активную policy_version, cache invalidation и отсутствие stale allow.	Тестовый запрещённый tool call блокируется.
6. Assess effects	Проверить tool calls, RAG retrieval, export, изменённые объекты и необратимые действия.	Blast radius зафиксирован.
7. Rollback/notify	Запустить rollback/compensation; для необратимых эффектов уведомить владельцев и recipients.	RTO и результат записаны.
8. Reissue	После устранения причины - новая attestation, новая scoped credential, текущая policy.	Новая сессия проходит positive/negative tests.
9. Close	Обновить incident journal, threat model, tests, runbook и policy audit.	Closure criteria выполнены.

Операторские точки доступа (заполнить до пилота): IAM console/CLI: _____; PDP dashboard: _____; PEP control: _____; SIEM query: _____; NetFlow/Syslog dashboard: _____; On-call contacts: _____.

Часть III. Исключения и waiver-процесс

- Waiver допускается только для некритичного либо временно ограниченного сценария. Для critical agent отсутствие attestation, attribution или enforcement не может быть компенсировано бумажным исключением.
- Запрос содержит: агент/сервис, нарушаемое требование, бизнес-обоснование, срок, owner, risk rating, compensating controls, monitoring plan и exit plan.
- Согласование: system owner + security architect; high/critical - дополнительно CISO. Critical policy waiver требует принципа двух лиц.
- Максимальный срок waiver задаётся политикой организации; рекомендуется не более 30-90 дней. Автопродление запрещено.
- Компенсирующие меры: более узкие network scopes, lower data budgets, mandatory human approval, enhanced logging, increased review cadence, sandbox/read-only mode.

- Waiver автоматически истекает; после expiry агент блокируется либо переводится в approved control state.
- Все waiver и изменения логируются и отражаются на dashboard как отдельный риск.

Поле waiver	Значение
Waiver ID	
Agent/service	
Requirement	
Business justification	
Risk rating	
Compensating controls	
Owner	
Approvers	
Start/expiry	
Exit plan	
Review cadence	
Status	

Часть IV. OPA/Rego reference policy

Полный файл поставляется отдельно: RAG_policy_Zero_Trust_v5.rego. Он включает session expiry, attestation, policy version, metadata scope, task/tree budgets, export domain/region и parent delegation scope.

```
package zero_trust.rag

# Reference implementation for OPA/Rego.
# Production requirements:
# 1. Counters must be stored in an external trusted atomic state store.
# 2. The agent must not have write access to policy, counters, attestation state, or policy-version state.
# 3. Parent/child permissions must be resolved by a trusted authorization service.
# 4. Destination domain/region controls require authoritative classification data.

default allow := false

required_context := {"agent_id", "session_id", "task_id", "root_agent_id", "policy_version"}

missing_context contains key if {
  key := required_context[_]
  not object.get(input.context, key, false)
}

session_ok if {
  input.agent.session_expiry_ns > time.now_ns()
}

policy_version_ok if {
  input.context.policy_version == data.policy.current_version
}

attestation_ok if {
  input.agent.criticality in {"low", "medium"}
}

attestation_ok if {
  input.agent.criticality in {"high", "critical"}
  input.agent.attestation.status == "verified"
  input.agent.attestation.image_digest == data.policy.allowed_images[input.agent.agent_id]
  input.agent.attestation.verified_at_ns + data.policy.attestation_max_age_ns > time.now_ns()
}

metadata_scope_ok if {
  input.request.metadata.project_id == input.task.project_id
  input.request.metadata.owner_id == input.task.owner_id
  input.request.metadata.tenant_id == input.task.tenant_id
}

allowed_data_classes := object.get(data.policy.agents[input.agent.agent_id], "allowed_data_classes", [])
requested_data_classes := object.get(input.request, "data_classes", [])
```

```

data_classes_ok if {
  every class in requested_data_classes {
    class in allowed_data_classes
  }
}

request_limits_ok if {
  input.request.top_k <= data.policy.rag.max_top_k
  input.request.requested_tokens <= data.policy.rag.max_tokens_per_request
}

task_budget_ok if {
  input.usage.task_consumed_tokens + input.request.requested_tokens <= data.policy.rag.max_tokens_per_task
}

tree_budget_ok if {
  input.usage.tree_consumed_tokens + input.request.requested_tokens <= data.policy.rag.max_tokens_per_agent_tree
}

request_rate_ok if {
  input.usage.requests_last_minute < data.policy.rag.max_requests_per_minute
}

# Export control. Apply when the request causes data to leave the trusted retrieval boundary.
destination_ok if {
  not input.request.export
}

destination_ok if {
  input.request.export
  input.request.destination_domain in data.policy.export.allowed_domains
  input.request.destination_region in data.policy.export.allowed_regions
  input.request.export_bytes <= data.policy.export.max_bytes_per_task - input.usage.task_exported_bytes
}

# Child permissions must be a subset of the parent delegation scope.
parent_scope_ok if {
  not input.context.parent_agent_id
}

parent_scope_ok if {
  input.context.parent_agent_id
  every tool in input.request.requested_tools {
    tool in input.delegation.parent_allowed_tools
  }
  every class in requested_data_classes {
    class in input.delegation.parent_allowed_data_classes
  }
  input.request.requested_tokens <= input.delegation.parent_remaining_token_budget
}

allow if {
  count(missing_context) == 0
  session_ok
  policy_version_ok
  attestation_ok
  metadata_scope_ok
  data_classes_ok
  request_limits_ok
  task_budget_ok
  tree_budget_ok
  request_rate_ok
  destination_ok
  parent_scope_ok
}

deny_reasons contains "missing_context" if count(missing_context) > 0
deny_reasons contains "session_expired" if not session_ok
deny_reasons contains "policy_version_mismatch" if not policy_version_ok
deny_reasons contains "attestation_failed" if not attestation_ok
deny_reasons contains "metadata_scope_violation" if not metadata_scope_ok
deny_reasons contains "data_class_violation" if not data_classes_ok
deny_reasons contains "request_limit_exceeded" if not request_limits_ok
deny_reasons contains "task_budget_exceeded" if not task_budget_ok
deny_reasons contains "agent_tree_budget_exceeded" if not tree_budget_ok
deny_reasons contains "request_rate_exceeded" if not request_rate_ok
deny_reasons contains "destination_not_allowed" if not destination_ok

```

```
deny_reasons contains "parent_scope_exceeded" if not parent_scope_ok

response := {
  "allow": allow,
  "deny_reasons": sort([r | r := deny_reasons[_]]),
  "policy_version": data.policy.current_version,
  "decision_time_ns": time.now_ns(),
}
```

Часть V. Тестирование стоп-критериев и dashboard

Полный набор тест-кейсов и интерактивный шаблон dashboard поставляются отдельным XLSX. Каждый stop criterion имеет positive/negative test, expected result, evidence и owner. Dashboard показывает enforcement, attestation, budgets, attribution coverage, revocation, policy changes, waivers и incident response в реальном времени.

Часть VI. Журнал инцидента prompt injection

Отдельный шаблон v5 включает policy change after incident, расширенный root cause, слепые зоны, revoke/reissue, rollback RTO и closure criteria.